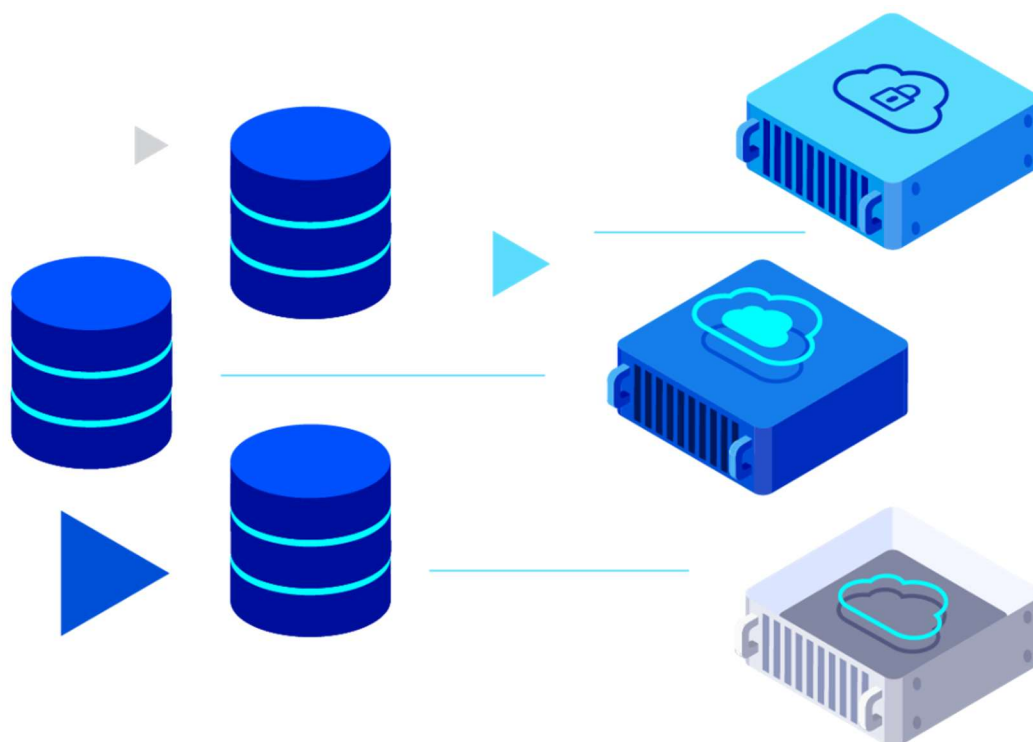
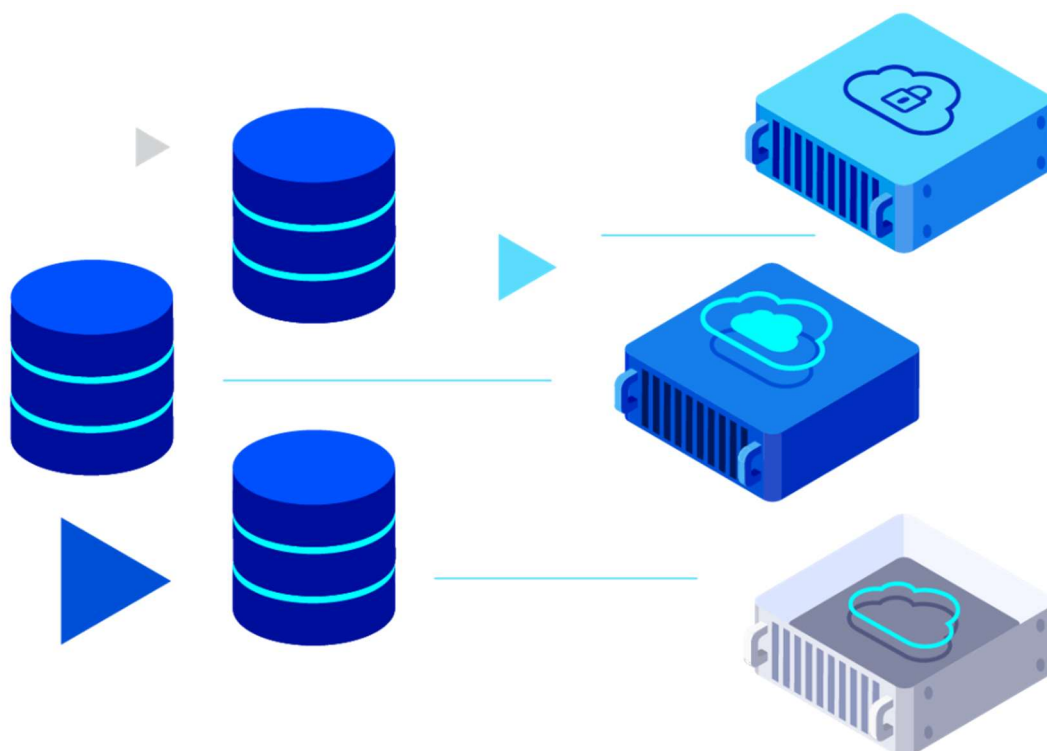




PRACTICA 2 UD 3: DATOS SERVIDOR WEB

Hecho por: Izan Navarro



# INDICE

|                                                                                                                           |           |
|---------------------------------------------------------------------------------------------------------------------------|-----------|
| INTRODUCCION .....                                                                                                        | 3         |
| <b>EJERCICIO 1 - NMAP .....</b>                                                                                           | <b>3</b>  |
| \$ nmap -p ***** -Pn --script=http-server-header URL .....                                                                | 3         |
| \$ nmap -p ***** -Pn --script=http-header URL .....                                                                       | 4         |
| \$ nmap -p ***** -Pn --script=http-header URL   grep -i Strict-Transport-Security ....                                    | 5         |
| \$ nmap -p *****-sV -Pn --script=http-header URL .....                                                                    | 5         |
| \$ nmap -p ***** -Pn --script=http-security-headers URL .....                                                             | 6         |
| <b>EJERCICIO 2 – WGET Y CURL .....</b>                                                                                    | <b>6</b>  |
| WGET -S <url> -q: .....                                                                                                   | 7         |
| CURL -I <url> : .....                                                                                                     | 7         |
| Comparación con NSE (security-headers): .....                                                                             | 8         |
| <b>EJERCICIO 3 – WIRESHARK y HERRAMIENTAS DE DESARROLLADORES .....</b>                                                    | <b>8</b>  |
| 1) Entramos a la interfaz de WIRESHARK .....                                                                              | 8         |
| 2) Seleccionamos y filtramos por el puerto 80 al host destino .....                                                       | 9         |
| 3) Cabeceras de los paquetes TCP .....                                                                                    | 9         |
| 4) Mostramos el Servidor Web, Versión y PHP (si existe) .....                                                             | 9         |
| 5) Desde interfaz de Firefox .....                                                                                        | 10        |
| 6) Hacemos consulta a la http vulnerable ( <a href="http://testphp.vulnweb.com/">http://testphp.vulnweb.com/</a> ): ..... | 10        |
| <b>EJERCICIO 4 – WHATWEB .....</b>                                                                                        | <b>10</b> |
| 1) Ataque por defecto a la IP Metasploitable 2.0 .....                                                                    | 11        |
| 2) Ataque con el parámetro -v .....                                                                                       | 11        |
| 3) Ataque con el parámetro -a .....                                                                                       | 11        |
| <b>EJERCICIO 5 – Ocultar identificación del servidor .....</b>                                                            | <b>12</b> |
| 1) Comprobar Información Expuesta .....                                                                                   | 12        |
| 3) ServerTokens Prod y ServerSignature Off .....                                                                          | 12        |
| 4) Ocultar Información de PHP .....                                                                                       | 13        |
| 5) Reiniciar Apache .....                                                                                                 | 13        |
| 6) Comprobación desde Kali (ANTES/DESPUES) .....                                                                          | 13        |
| <b>BIBLIOGRAFÍA: .....</b>                                                                                                | <b>13</b> |

## INTRODUCCION

En esta práctica comprobaremos los datos de los servidores donde se almacena las páginas Web. Obtendremos datos como versiones de servidor y sistema operativo, así como datos de las páginas web.

### PREPARACIÓN DEL ESCENARIO

Para realizar esta práctica necesitarás:

- MV Kali en modo puente
- MV Metasploitable 2 en modo puente.

Cuando necesites probar una URL puedes usar:

- <http://testphp.vulnweb.com/>

**Hay que entregar memoria en la que expliques los resultados obtenidos.**

## EJERCICIO 1- NMAP

NMAP permite ejecutar pruebas de detección de versiones en determinados servicios con la opción `-sV` y el parámetro `--version-intensity` que permite indicar la intensidad de las pruebas.

Además, dispone del script `http-server-header` que realiza comprobaciones similares, pero con un tiempo de respuesta más rápido.

Realiza diferentes test de comprobación de versión de servidor web tanto por puerto 80 como por puerto 443 en algunas webs utilizando el siguiente comando y adjunta capturas:

`$ nmap-p *****-Pn --script=http-server-header URL`

A una dirección vulnerable:

```
(izan@kali-jose)-[~]
$ sudo nmap -p 80,443 -Pn --script=http-server-header testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-12 11:45 EST
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.39s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com

PORT      STATE      SERVICE
80/tcp    open      http
443/tcp   filtered  https

Nmap done: 1 IP address (1 host up) scanned in 6.94 seconds
```

A mi máquina Metasploide 2.0 con su IP:

```
(izan@kali-jose)-[~]
$ sudo nmap -p 80,443 -Pn --script=http-server-header 172.16.112.78
[sudo] password for izan:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-12 12:11 EST
Nmap scan report for 172.16.112.78
Host is up (0.055s latency).

PORT      STATE      SERVICE
80/tcp    filtered  http
443/tcp    filtered  https

Nmap done: 1 IP address (1 host up) scanned in 0.27 seconds
```

\$ nmap-p \*\*\*\*\*-Pn --script=http-header URL

A mi máquina Metasploide 2.0:

```
(izan@kali-jose)-[~]
$ sudo nmap -p 80,443 -Pn --script=http-headers 172.16.112.78
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-12 12:12 EST
Nmap scan report for 172.16.112.78
Host is up (0.064s latency).

PORT      STATE      SERVICE
80/tcp    filtered  http
443/tcp    filtered  https

Nmap done: 1 IP address (1 host up) scanned in 0.53 seconds
```

A una URL que tenemos de test vulnerable:

```
(izan@kali-jose)-[~]
$ sudo nmap -p 80,443 -Pn --script=http-headers http.badssl.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-12 12:23 EST
Nmap scan report for http.badssl.com (104.154.89.105)
Host is up (0.14s latency).
rDNS record for 104.154.89.105: 105.89.154.104.bc.googleusercontent.com

PORT      STATE SERVICE
80/tcp    open  http
| http-headers:
|   Server: nginx/1.10.3 (Ubuntu)
|   Date: Fri, 12 Dec 2025 17:24:03 GMT
|   Content-Type: text/html
|   Content-Length: 483
|   Last-Modified: Tue, 09 Dec 2025 21:01:17 GMT
|   Connection: close
|   ETag: "69388e1d-1e3"
|   Cache-Control: no-store
|   Accept-Ranges: bytes
|
|_ (Request type: HEAD)
443/tcp    open  https
| http-headers:
|   Server: nginx/1.10.3 (Ubuntu)
|   Date: Fri, 12 Dec 2025 17:24:04 GMT
|   Content-Type: text/html
|   Content-Length: 194
|   Connection: close
|   Location: http://http.badssl.com/
|
|_ (Request type: GET)

Nmap done: 1 IP address (1 host up) scanned in 2.75 seconds
```

Utiliza el comando anterior para comprobar si los servidores webs de diferentes bancos de España utilizan HSTS y adjunta los resultados.

\$ nmap-p \*\*\*\*\*-Pn --script=http-header URL | grep-i Strict-Transport-Security

Ejecutamos el commando correspondiente con “grep -i “ y nos mostrará si dicha URL bancaria utiliza HSTS. En este caso, Santander.com

```
(izan@kali-jose)-[~]
$ sudo nmap -p 80,443 -Pn --script=http-headers santander.com | grep -i Strict-Transport-Security
| Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
```

Otra opción que nos ofrece nmap es usar el parámetro -sV . Realiza alguna comprobación de versión con algún dominio y adjunta resultados y compara con el script NSE http-server-header

\$ nmap-p \*\*\*\*\*-sV-Pn --script=http-header URL

Utilizando http-headers, hacienda llamamiento a “Adidas.com”:

```
(izan@kali-jose)-[~]
$ sudo nmap -p 80,443 -sV -Pn adidas.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-12 12:41 EST
Nmap scan report for adidas.com (87.237.217.231)
Host is up (0.19s latency).

PORT      STATE SERVICE      VERSION
80/tcp    open  http-proxy   F5 BIG-IP load balancer http proxy
443/tcp    open  ssl/http-proxy F5 BIG-IP load balancer http proxy
Service Info: Device: load balancer

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.99 seconds
```

Utilizando http-server-headers, haciendo llamamiento a “adidas.com”:

```
(izan@kali-jose)-[~]
$ sudo nmap -p 80,443 --script=http-server-header adidas.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-12 12:41 EST
Nmap scan report for adidas.com (87.237.217.231)
Host is up (0.077s latency).

PORT      STATE SERVICE
80/tcp    open  http
|_http-server-header: BigIP
443/tcp    open  https
|_http-server-header: BigIP

Nmap done: 1 IP address (1 host up) scanned in 1.98 seconds
```

Comparando ambos podemos ver que:

sV → Detecta versiones activamente de una URL enviando probes.

--script=http-server-header → Se usa para leer cabeceras HTTP server, NO realiza detección activa de versiones.

Otro script de NSE que puedes probar es http-security-headers para mostrar si un servidor web incluye los encabezados de seguridad recomendados por OWASP como HSTS, X-Frame-Options, X-XSS-Protection, X-Content-Type-Options, Content-SecurityPolicy entre otros (ver la ayuda del script).



Ejecuta este script NSE contra algunos servidores web para mostrar su nivel de seguridad. Haz una comparación de un servidor vulnerable y otro seguro.

\$ nmap-p \*\*\*\*\*-Pn --script=http-security-headers URL

Utilizando http-security-headers, haciendo llamamiento a "nike.com":

```
(izan@kali-jose)-[~]
$ sudo nmap -p 80,443 -Pn --script=http-security-headers nike.com
[sudo] password for izan:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-14 11:39 EST
Nmap scan report for nike.com (18.154.29.6)
Host is up (0.12s latency).
Other addresses for nike.com (not scanned): 18.154.29.62 18.154.29.74 18.154.29.93
rDNS record for 18.154.29.6: server-18-154-29-6.mad53.r.cloudfront.net

PORT      STATE SERVICE
80/tcp    open  http
| http-security-headers:
|   Strict_Transport_Security:
|     Header: Strict-Transport-Security: max-age=2628000 ; includeSubDomains
|     Expires:
|_    Header: Expires: Sun, 14 Dec 2025 16:39:31 GMT
443/tcp    open  https
| http-security-headers:
|   Strict_Transport_Security:
|     Header: Strict-Transport-Security: max-age=2628000 ; includeSubDomains
|     Expires:
|_    Header: Expires: Sun, 14 Dec 2025 16:39:31 GMT

Nmap done: 1 IP address (1 host up) scanned in 0.85 seconds
```

Utilizando http-security-headers a nuestra máquina Metasploide 2.0:

```
(izan@kali-jose)-[~]
$ sudo nmap -p 80,443 -Pn --script=http-security-headers 192.168.1.217
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-14 11:41 EST
Nmap scan report for 192.168.1.217
Host is up (0.029s latency).

Bug in http-security-headers: no string output.
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    closed https
MAC Address: 08:00:27:01:40:9B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 3.20 seconds
```

Como podemos observar una sí que nos muestra en la salida los encabezados de seguridad que OWASP recomienda, mientras que el otro, no imprime nada, solo muestra la información por defecto de los parámetros. Esta es una forma de evaluar la seguridad de los servidores web.

## EJERCICIO 2 – WGET Y CURL

Realiza pruebas con los servidores del ejercicio anterior y compara los resultados de ellos y el de NSE http-headers. (Adjunta capturas de pantalla) \$ wget -S URL -q \$ curl -I URL

WGET-S <url>-q:

Ejecutando el comando en un servidor seguro como “nike.com”:

```
(izan@kali-jose)-[~]
$ wget -S nike.com -q
Prepended http:// to 'nike.com'
HTTP/1.1 301 Moved Permanently
Content-Length: 0
Connection: keep-alive
Server: CloudFront
Date: Fri, 12 Dec 2025 18:45:01 GMT
Strict-Transport-Security: max-age=63072000
Cache-Control: max-age=300, s-maxage=604800
Location: https://www.nike.com/
X-Cache: Hit from cloudfront
Via: 1.1 7b3d4fbf3608ac6e273cc0ee9577e3a.cloudfront.net (CloudFront)
X-Amz-Cf-Pop: MAD53-P1
X-Amz-Cf-Id: -N6yLDGN2klQd1MFab_7h2zq0vc0D9A36pVj0vazsSr08a8S-GvYg==
Age: 168687
HTTP/1.1 302 Moved Temporarily
Server: AkamaiGHost
Content-Length: 0
Location: https://www.nike.com/es/
Date: Sun, 14 Dec 2025 17:36:29 GMT
Connection: keep-alive
Set-Cookie: geoLoc=ES;rc=VC;tp=vhigh;tz=GMT+1;la=39.47;lo=-0.37; path=/; domain=.nike.com
Set-Cookie: ni_d=C146C431-32E0-46C2-ACB5-AE1B3E4E4595; expires=Wed, 13-Jan-2027 17:36:29 GMT; path=/; domain=.nike.com; secure
Server-Timing: cdn-cache; desc=HIT
Server-Timing: edge; dur=1
Strict-Transport-Security: max-age=2628000 ; includeSubDomains
Akamai-GRN: 0.c46c1402.1765733789.3f323b90
Server-Timing: ak_pi; desc="1765733789042_34892996_1060256656_46_8868_18_23_-";dur=1
HTTP/1.1 200 OK
Server: unified-edge-router
Content-Length: 648153
Content-Type: text/html; charset=UTF-8
Set-Cookie: at_lp_expire=0;page/es/; Max-Age=3600; Path=/
X-Commerce-Region: us-east-1
Akamai-GRN: 0.c46c1402.1765733789.3f323c3a
Strict-Transport-Security: max-age=2628000 ; includeSubDomains
Server-Timing: edge; dur=1
Server-Timing: cdn-cache; desc=HIT
Vary: Accept-Encoding
X-Akamai-Transformed: 9 ~ 0 pmb=NONE,1MRUN,3
X-EdgeConnect-Origin-MEX-Latency: 222
X-EdgeConnect-MidMile-RTT: 98
X-B3-TraceId: 967c34fb07c3c3f989e3753f7a097d9a
Etag: "f718xlm92260f"
Permissions-Policy: ch-ua-model=("https://sdk-api-v1.singular.net"), ch-ua-platform-version=("https://sdk-api-v1.singular.net"), ch-ua-full-version-list=("https://sdk-api-v1.singular.net")
```

Ejecutando el comando a la IP de nuestro servidor Metasploide 2.0:

```
(izan@kali-jose)-[~]
$ wget -S 192.168.1.217 -q
Prepended http:// to '192.168.1.217'
HTTP/1.1 200 OK
Date: Sun, 14 Dec 2025 16:08:55 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Length: 891
Keep-Alive: timeout=15, max=100
Connection: Keep-Alive
Content-Type: text/html
```

CURL-I <url> :

Ejecutando el comando en un servidor seguro como “nike.com”:

```
(izan@kali-jose)-[~]
$ curl -I nike.com
HTTP/1.1 301 Moved Permanently
Content-Length: 0
Connection: keep-alive
Server: CloudFront
Date: Fri, 12 Dec 2025 18:45:01 GMT
Strict-Transport-Security: max-age=63072000
Cache-Control: max-age=300, s-maxage=604800
Location: https://www.nike.com/
X-Cache: Hit from cloudfront
Via: 1.1 fa8c2c6e6d3ef2d256a56b03615fe530.cloudfront.net (CloudFront)
X-Amz-Cf-Pop: MAD53-P1
X-Amz-Cf-Id: nXRA00m_vHLEXKNXXv7VoYlVYpR0uzKogz7b_s5PvrMjnfGfhrsWeA==
Age: 169067
```

Ejecutando el comando a la IP de nuestro servidor Metasploide 2.0:

```
(izan@kali-jose)-[~]
$ curl -I 192.168.1.217
HTTP/1.1 200 OK
Date: Sun, 14 Dec 2025 16:09:27 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html
```

Comparación con NSE (security-headers):

Los comandos wget y curl nos muestran los headers en bruto, los cuales son más útiles para ver detalles técnicos. En cambio, 'http-security-headers' se utiliza para hacer evaluaciones rápidas de seguridad las cuales son ideales para auditorías y prácticas de OWASP.

En el contexto anterior el parámetro -S significa que está en **modo Sigilo**, el parámetro -I significa que **muestra únicamente los encabezados HTTP** de la respuesta del servidor.

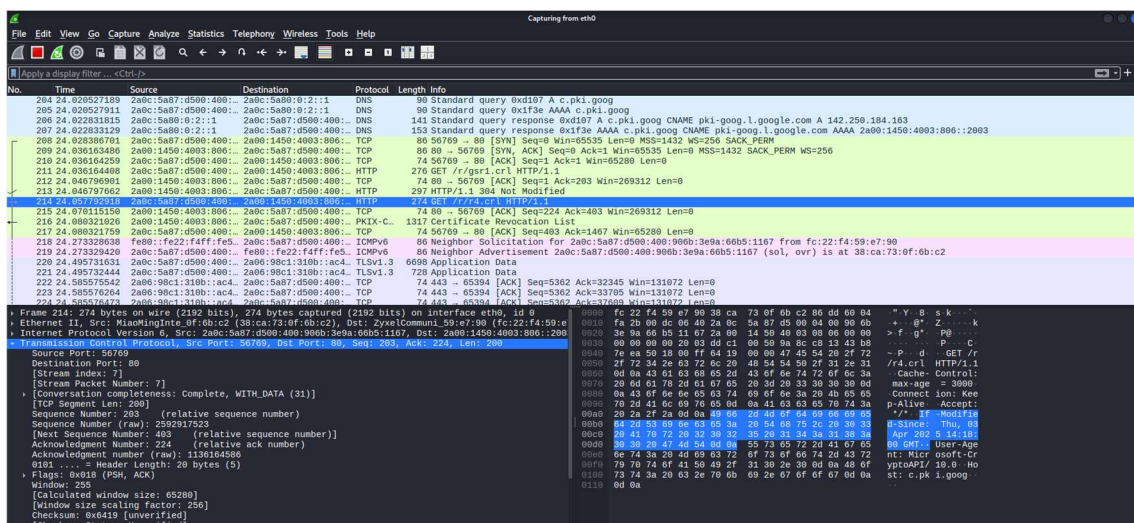
## EJERCICIO 3 – WIRESHARK y HERRAMIENTAS DE DESARROLLADORES

En la maquina Kali abre Wireshark y filtra por el puerto 80 y el host de destino. Muestra capturas de pantalla donde se aprecie las cabeceras de los paquetes TCP, identifica el servidor web, versión y versión de PHP si tiene.

Ahora realiza lo mismo usando las herramientas de desarrollador del navegador.

1) Entramos a la interfaz de WIRESHARK

y nos conectamos a nuestra red por defecto, normalmente (y en mi caso) 'eth0':





2) Seleccionamos y filtramos por el puerto 80 al host destino

Le damos click derecho y seleccionamos filtrar > Flujo TCP. Filtramos por la IP de mi server Metasploide:

```

tcp.port==80 && ip.dst==192.168.1.217

No.    Time           Source                Destination           Protocol  Length  Info
-----
1588  214.716281460  192.168.1.146        192.168.1.217        TCP      74      39004 -> 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=4019666836 TSecr=0 WS=128
1593  214.770255922  192.168.1.146        192.168.1.217        TCP      66      39004 -> 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=4019666890 TSecr=210253
1594  214.771544503  192.168.1.146        192.168.1.217        HTTP     144     HEAD / HTTP/1.1
1597  214.824323996  192.168.1.146        192.168.1.217        TCP      66      39004 -> 80 [ACK] Seq=79 Ack=156 Win=64128 Len=0 TSval=4019667043 TSecr=210256
1598  214.924232396  192.168.1.146        192.168.1.217        TCP      66      39004 -> 80 [FIN, ACK] Seq=79 Ack=156 Win=64128 Len=0 TSval=4019667044 TSecr=210256
1600  214.956833843  192.168.1.146        192.168.1.217        TCP      66      39004 -> 80 [ACK] Seq=80 Ack=157 Win=64128 Len=0 TSval=4019667077 TSecr=210257

Frame 1597: 66 bytes on wire (528 bits), 66 bytes captured (528 bits) on interface eth0, id 0
Ethernet II, Src: PCSSystemtec-1f:b7:23 (08:00:27:1f:b7:23), Dst: PCSSystemtec-01:40:9b (08:00:27:01:40:9b)
Internet Protocol Version 4, Src: 192.168.1.146, Dst: 192.168.1.217
Transmission Control Protocol, Src Port: 39004, Dst Port: 80, Seq: 79, Ack: 156, Len: 0
  Source Port: 39004
  Destination Port: 80
  [Stream index: 13]
  [Stream Packet Number: 7]
  [Conversation completeness: Complete, WITH_DATA (31)]
  [TCP Segment Len: 0]
  Sequence Number: 79 (relative sequence number)
  Sequence Number (raw): 1456292971
  [Next Sequence Number: 79 (relative sequence number)]
  Acknowledgment Number: 156 (relative ack number)
  Acknowledgment number (raw): 2603577178
  1000 .... = Header Length: 32 bytes (8)
  Flags: 0x010 (ACK)
  Window: 502
  [Calculated window size: 64256]
  [Window size scaling factor: 128]
  Checksum: 0x84e2 [unverified]
  [Checksum Status: Unverified]
  Urgent Pointer: 0
  Options: (12 bytes), No-Operation (NOP), No-Operation (NOP), Timestamps
  [Timestamps]
  [SEQ/ACK analysis]

```

3) Cabeceras de los paquetes TCP

```

Transmission Control Protocol, Src Port: 39004, Dst Port: 80, Seq: 1, Ack: 1, Len: 0
  Source Port: 39004
  Destination Port: 80
  [Stream index: 13]
  [Stream Packet Number: 3]
  [Conversation completeness: Complete, WITH_DATA (31)]
  [TCP Segment Len: 0]
  Sequence Number: 1 (relative sequence number)
  Sequence Number (raw): 1456292971
  [Next Sequence Number: 1 (relative sequence number)]
  Acknowledgment Number: 1 (relative ack number)
  Acknowledgment number (raw): 2603577178
  1000 .... = Header Length: 32 bytes (8)
  Flags: 0x010 (ACK)
  Window: 502
  [Calculated window size: 64256]
  [Window size scaling factor: 128]
  Checksum: 0x84e2 [unverified]
  [Checksum Status: Unverified]
  Urgent Pointer: 0
  Options: (12 bytes), No-Operation (NOP), No-Operation (NOP), Timestamps
  [Timestamps]
  [SEQ/ACK analysis]

```

4) Mostramos el Servidor Web, Versión y PHP (si existe)

```

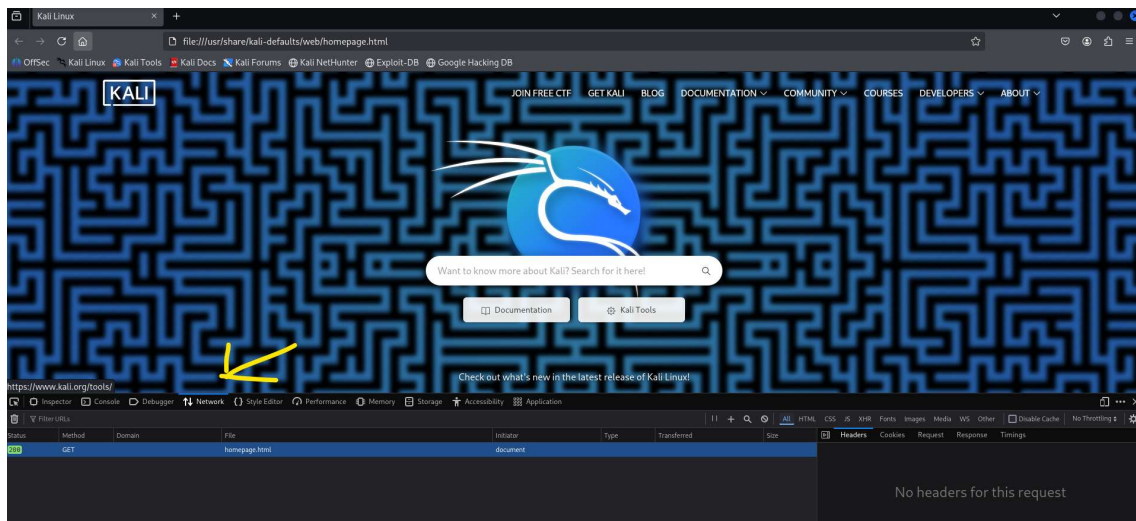
Hypertext Transfer Protocol
  HEAD / HTTP/1.1\r\n
  Host: 192.168.1.217\r\n
  User-Agent: curl/8.15.0\r\n
  Accept: */*\r\n
  \r\n

```

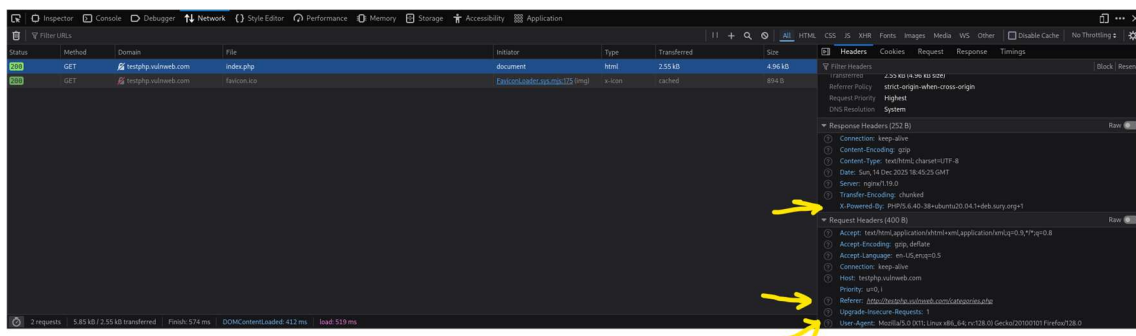
El host == a la IP de mi VM Metasploide 2.0

La versión de mi herramienta Curl == 8.15.0

## 5) Desde interfaz de Firefox



## 6) Hacemos consulta a la http vulnerable (http://testphp.vulnweb.com/):



En la parte izquierda tenemos la petición GET 200 que recibimos al consultar el index.php, este contiene en la parte derecha toda la información y sus headers donde podremos comprobar la versión de PHP, el User-Agent...

Este caso si que tiene versión ya que usamos un servidor web distinto a la máquina Metasploitable 2.0.

## EJERCICIO 4 – WHATWEB

Una herramienta para la línea de comandos de GNU/Linux, es whatweb, disponible en Kali, Parrot y en muchos repositorios. Realiza muchas más comprobaciones y utiliza muchos plugins que puedes consultar con la opción -l (ele minúscula) o -l para ayuda más detallada.

Utiliza la herramienta sin opciones, indicando el servidor web de pruebas y después compara el resultado viendo otras opciones como la -v o la -a y explica qué hacen estas opciones.

## Lánzalo contra la maquina METASPLOITABLE 2

## 1) Ataque por defecto a la IP Metasploitable 2.0

```
(izan@kali-jose)-[~]
$ whatweb 192.168.1.217
ERROR Opening: https://192.168.1.217 - Connection refused - connect(2) for "192.168.1.217" port 443
http://192.168.1.217 [200 OK] Apache[2.2.8], Country[RESERVED][??], HTTPServer[Ubuntu Linux][Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.1.217], PHP[5.2.4-2ubuntu5.10], Title[Metasploitable2 - Linux], WebDAV[2], X-Powered-By[PHP/5.2.4-2ubuntu5.10]
```

Aquí podremos ver toda la información que devuelve whatweb acerca de nuestra máquina Metasploitable 2.0

## 2) Ataque con el parámetro -v

```
(izan@kali-jose)-[~]
$ whatweb -v 192.168.1.217
[+] Simple hostname detected: 192.168.1.217. Testing both HTTP and HTTPS.
ERROR Opening: https://192.168.1.217 - Connection refused - connect(2) for "192.168.1.217" port 443
WhatWeb report for http://192.168.1.217
Status      : 200 OK
Title       : Metasploitable2 - Linux
IP          : 192.168.1.217
Country     : RESERVED, ZZ
Summary     : Apache[2.2.8], HTTPServer[Ubuntu Linux][Apache/2.2.8 (Ubuntu) DAV/2], PHP[5.2.4-2ubuntu5.10], WebDAV[2], X-Powered-By[PHP/5.2.4-2ubuntu5.10]
```

Ahora con -v (verbose) mostramos información más detallada como: Plugins, cabecera HTTP...

```
Detected Plugins:
[ Apache ]
The Apache HTTP Server Project is an effort to develop and
maintain an open-source HTTP server for modern operating
systems including UNIX and Windows NT. The goal of this
project is to provide a secure, efficient and extensible
server that provides HTTP services in sync with the current
HTTP standards.

Version      : 2.2.8 (from HTTP Server Header)
Google Dorks: (3)
Website      : http://httpd.apache.org/

[ HTTPServer ]
HTTP server header string. This plugin also attempts to
identify the operating system from the server header.

OS           : Ubuntu Linux
String       : Apache/2.2.8 (Ubuntu) DAV/2 (from server string)

[ PHP ]
PHP is a widely-used general-purpose scripting language
that is especially suited for Web development and can be
embedded into HTML. This plugin identifies PHP errors,
modules and versions and extracts the local file path and
username if present.

Version      : 5.2.4-2ubuntu5.10
Google Dorks: (3)
Website      : http://www.php.net/

[ WebDAV ]
Web-based Distributed Authoring and Versioning (WebDAV) is
a set of methods based on the Hypertext Transfer Protocol
(HTTP) that facilitates collaboration between users in
editing and managing documents and files stored on World
Wide Web servers. - More Info:
http://en.wikipedia.org/wiki/WebDAV

Version      : 2

[ X-Powered-By ]
X-Powered-By HTTP header

String       : PHP/5.2.4-2ubuntu5.10 (from x-powered-by string)

HTTP Headers:
HTTP/1.1 200 OK
Date: Sun, 14 Dec 2025 16:28:52 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
```

## 3) Ataque con el parámetro -a

```
(izan@kali-jose)-[~]
$ whatweb -a 3 192.168.1.217
ERROR Opening: https://192.168.1.217 - Connection refused - connect(2) for "192.168.1.217" port 443
http://192.168.1.217 [200 OK] Apache[2.2.8], Country[RESERVED][??], HTTPServer[Ubuntu Linux][Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.1.217], PHP[5.2.4-2ubuntu5.10], Title[Metasploitable2 - Linux], WebDAV[2], X-Powered-By[PHP/5.2.4-2ubuntu5.10]
```

El parámetro -a X define el nivel de agresividad del escaneo, siendo este del 0 al 3 (0 = silencioso y 3 = máxima agresividad).

Nos muestra la misma información que la escaneada por defecto.

## EJERCICIO 5 – Ocultar identificación del servidor

Una técnica para evitar que un atacante averigüe fácilmente la versión del servidor, al menos usando el encabezado Header de las respuestas, es manipulando esta información.

Investiga cómo ocultar los servidores del centro e impleméntalo en un servidor web Apache de pruebas o el de la máquina Metasploitable. Documenta en la memoria cómo lo has realizado.

Para empezar seguiremos una serie de pautas:

### 1) Comprobar Información Expuesta

```
(izan@kali-jose)-[~]  
$ curl -I 192.168.1.217  
HTTP/1.1 200 OK  
Date: Sun, 14 Dec 2025 16:32:58 GMT  
Server: Apache/2.2.8 (Ubuntu) DAV/2  
X-Powered-By: PHP/5.2.4-2ubuntu5.10  
Content-Type: text/html
```

### 2) ACCEDER A METASPLOIDE Y LOCALIZAR CONFIG APACHE

Accedemos dentro de la consola de nuestra VM metasploide y buscamos el archivo de configuración de apache:

```
msfadmin@metasploitable:~$ sudo nano /etc/apache2/apache2.conf
```

### 3) ServerTokens Prod y ServerSignature Off

Cambiaremos la línea “ServerTokens Full” > “ServerTokens Prod” y añadiremos la línea “ServerSignature Off”

```
#  
# ServerTokens  
# This directive configures what you return as the Server HTTP response  
# Header. The default is 'Full' which sends information about the OS-Type  
# and compiled in modules.  
# Set to one of: Full | OS | Minor | Minimal | Major | Prod  
# where Full conveys the most information, and Prod the least.  
#  
ServerTokens Full
```

```
#  
# ServerTokens  
# This directive configures what you return as the Server HTTP response  
# Header. The default is 'Full' which sends information about the OS-Type  
# and compiled in modules.  
# Set to one of: Full | OS | Minor | Minimal | Major | Prod  
# where Full conveys the most information, and Prod the least.  
#  
ServerTokens Prod  
ServerSignature Off_
```



ServerTokens Prod → Muestra solo “Server: Apache”

ServerSignature Off → Elimina versión en páginas de error



## 4) Ocultar Información de PHP

Entramos dentro del archivo de php con la ruta indicada debajo:

```
msfadmin@metasploitable:~$ sudo nano /etc/php5/apache2/php.ini _
```

Una vez dentro cambiamos la línea `Expose_php = On` > `Expose_php Off` para así ocultar la información de PHP:

```
; Decides whether PHP may expose the fact that it is installed on the server  
; (e.g. by adding its signature to the Web server header). It is no security  
; threat in any way, but it makes it possible to determine whether you use PHP  
; on your server or not.  
expose_php = On
```

```
; Decides whether PHP may expose the fact that it is installed on the server  
; (e.g. by adding its signature to the Web server header). It is no security  
; threat in any way, but it makes it possible to determine whether you use PHP  
; on your server or not.  
expose_php = Off
```



## 5) Reiniciar Apache

```
msfadmin@metasploitable:~$ sudo /etc/init.d/apache2 restart  
* Restarting web server apache2 [ OK ]
```

## 6) Comprobación desde Kali (ANTES/DESPUES)

```
(izan@kali-jose)-[~]  
$ curl -I 192.168.1.217  
HTTP/1.1 200 OK  
Date: Sun, 14 Dec 2025 16:32:58 GMT  
Server: Apache/2.2.8 (Ubuntu) DAV/2  
X-Powered-By: PHP/5.2.4-2ubuntu5.10  
Content-Type: text/html
```

```
(izan@kali-jose)-[~]  
$ curl -I 192.168.1.217  
HTTP/1.1 200 OK  
Date: Sun, 14 Dec 2025 16:36:44 GMT  
Server: Apache  
X-Powered-By: PHP/5.2.4-2ubuntu5.10  
Content-Type: text/html
```

Y ya estaría!

## BIBLIOGRAFÍA:

Documentación oficial Apache – ServerTokens

<https://httpd.apache.org/docs/2.4/mod/core.html#servertokens>

Documentación Apache – ServerSignature

<https://httpd.apache.org/docs/2.4/mod/core.html#serversignature>

CSIRT – Ocultar versión de Apache

<https://www.csirt.gob.bo/es/publicaciones/ocultar-la-version-de-apache>